Plan of Action & Milestones

RHEL 9 DISA STIG — Post-Remediation Unresolved Findings

18 Open Items
Scan: 21 April 2026
Baseline: 96.12% compliant

CAT I Open	CAT II Open	CAT III Open	Deferred / Cascading	Overall Compliance
5	8	5	5	96.12%
High Severity	Medium Severity	Low Severity	Auto-resolve w/ FIPS	+47.48pp improvement

POA&M — Master Findings Register

POA&M ID	STIG ID	CCE	Finding Title	CAT	Severity	Current Status	Target Date	Milestones	Lab Risk	Prod Risk	POC	Notes / Comments
POAM-001	RHEL-09-671010	CCE-88742-2	Enable FIPS Mode	I	High	Ongoing — Deferred to Next Build	Next provisioning cycle / Q3 2026	Q2 2026 — Submit change request for system rebuild with FIPS-enabled kickstart Q3 2026 — Rebuild system with fips=1 in installer boot parameters Q3 2026 — Post-install verification: fips-mode-setup --check; re-scan with OpenSCAP	Moderate	High	System Administrator	Cascading dependency: resolving this finding will auto-resolve POAM-002, POAM-003, POAM-006, POAM-007. Highest-impact single remediation action available.
POAM-002	RHEL-09-671010	CCE-86547-7	Enable Dracut FIPS Module	I	High	Ongoing — Deferred (Cascading Dependency)	Q3 2026 (simultaneous with POAM-001)	Q3 2026 — Install dracut-fips as part of FIPS-enabled rebuild: dnf install dracut-fips Q3 2026 — Regenerate initramfs post-FIPS enable: dracut -f Q3 2026 — Verify: lsinitrd /boot/initramfs-$(uname -r).img | grep fips	Moderate	High	System Administrator	Dependent on POAM-001. Will resolve automatically upon FIPS mode activation and initramfs rebuild.
POAM-003	RHEL-09-671015	CCE-83441-6	Set Kernel Parameter crypto.fips_enabled = 1	I	High	Ongoing — Deferred (Cascading Dependency)	Q3 2026 (simultaneous with POAM-001)	Q3 2026 — Enable FIPS mode (POAM-001); kernel sets this parameter automatically at boot Q3 2026 — Verify post-reboot: sysctl crypto.fips_enabled (expected: 1) Q3 2026 — Include in post-hardening OpenSCAP scan validation	Moderate	High	System Administrator	Dependent on POAM-001. Parameter cannot be set independently. Will auto-resolve upon FIPS mode activation.
POAM-004	RHEL-09-212045	CCE-83849-0	Set grub2 Bootloader Password	I	High	Planned — Pending Organizational	Q2 2026	Q2 2026 — Obtain organizational approval for grub2 superuser credential and naming convention	Low	High	System Administrator / ISSO	Requires site-specific credential. Cannot be pre-

POA&M ID	STIG ID	CCE	Finding Title	CAT	Severity	Current Status	Target Date	Milestones	Lab Risk	Prod Risk	POC	Notes / Comments
						Credential Policy		Q2 2026 — Generate PBKDF2 hash: grub2-mkpasswd-pbkdf2 and configure /etc/grub.d/01_users Q2 2026 — Rebuild grub.cfg, escrow credential in vault, verify with OpenSCAP rescan				configured in generic Ansible playbook. Coordinate with ISSO for credential policy before implementation.
POAM-005	RHEL-09-212040	CCE-87370-3	Set grub2 Admin Username (Non-Default)	I	High	Planned — Pending Organizational Credential Policy	Q2 2026 (simultaneous with POAM-004)	Q2 2026 — Coordinate with ISSO to select a non-default, organizationally-approved bootloader username Q2 2026 — Configure in /etc/grub.d/01_users alongside POAM-004 password configuration Q2 2026 — Verify: grep superusers /etc/grub.d/01_users confirms non-default value	Low	High	System Administrator / ISSO	Co-dependent with POAM-004. Must be implemented simultaneously. Username must not appear in any default configuration or documentation.
POAM-006	RHEL-09-255070	CCE-86208-6	SSH Client — Use FIPS 140-2 Validated MACs (openssh.config)	II	Medium	Ongoing — Deferred (Cascading Dependency on POAM-001)	Q3 2026 (with POAM-001)	Q3 2026 — Enable FIPS mode (POAM-001); FIPS crypto policy activates automatically Q3 2026 — Verify: update-crypto-policies --show (expected: FIPS) Q3 2026 — Confirm SSH MACs: ssh -Q mac | grep -v hmac-md5	Low	Medium	System Administrator	DEFAULT crypto policy still enforces strong MACs (hmac-sha2-256, hmac-sha2-512). Risk is absence of FIPS certification, not absence of strong algorithms.
POAM-007	RHEL-09-255075	CCE-87567-4	SSH Server — Use FIPS 140-2 Validated MACs (opensshserver.config)	II	Medium	Ongoing — Deferred (Cascading Dependency on POAM-001)	Q3 2026 (with POAM-001)	Q3 2026 — Enable FIPS mode (POAM-001); FIPS crypto policy activates for sshd automatically Q3 2026 — Verify sshd MACs: sshd -T | grep ^macs Q3 2026 — OpenSCAP rescan post-FIPS to confirm resolution	Low	Medium	System Administrator	SSH daemon is operational and uses strong algorithms under DEFAULT policy. Residual risk: absence of FIPS certification only.
POAM-008	RHEL-09-231035	CCE-83487-9	/var/tmp on Separate Partition	II	Medium	Planned — Pre-Provisioning Architectural Item	Q2 2026 — tmpfs alternative; or next build cycle	Q2 2026 — Evaluate tmpfs option: systemctl enable --now var-tmp.mount Q2 2026 — If tmpfs: verify mount options (nodev,nosuid,noexec) in /etc/fstab Q2 2026 — OpenSCAP rescan to confirm mount option compliance	Low	Medium	System Administrator	tmpfs mount is a viable post-install alternative that does not require repartitioning. Recommend as the expedient path for this finding.
POAM-009	RHEL-09-411095	CCE-88048-4	Only Authorized Local Users Permitted	II	Medium	Planned — Requires Organizational User Inventory	Q2 2026	Q2 2026 — ISSO/IAO audits /etc/passwd and approves authorized account list Q2 2026 — Lock or remove unauthorized accounts; inject approved list into var_accounts_authorized_local_users_regex Q2 2026 — OpenSCAP rescan to confirm no unauthorized accounts flagged	Low	Medium	ISSO / System Administrator	Unauthorized local accounts are a common persistence mechanism. This should be prioritized before any production deployment or external network exposure.

POA&M ID	STIG ID	CCE	Finding Title	CAT	Severity	Current Status	Target Date	Milestones	Lab Risk	Prod Risk	POC	Notes / Comments
POAM-010	**RHEL-09-213105**	CCE-86209-4	Disable Unprivileged User Namespaces	II	Medium	Risk Accepted — Functional Dependency (Container Runtime)	Q2 2026 — Risk acceptance documentation	Q2 2026 — Conduct container workload audit to inventory all workloads requiring user namespaces Q2 2026 — If no container workloads: apply sysctl user.max_user_namespaces=0 and rescan Q2 2026 — If containers present: prepare formal risk acceptance memo for AO signature	**Medium**	**Medium**	System Administrator / AO	SSG rule name _no_remediation suffix signals intentional gap. This is a policy decision, not a technical gap. AO must formally accept if container workloads are present.
POAM-011	**RHEL-09-431016**	CCE-86576-6	SELinux Context Elevation for Sudo	II	Medium	Under Review — Possible Scanner False Positive	Q2 2026 — Verification and remediation if needed	Q2 2026 — Manually verify: sudo -V | grep SELinux and grep -r use_pty /etc/sudoers /etc/sudoers.d/ Q2 2026 — If not configured: add Defaults use_pty and Defaults rolespec_copy to sudoers Q2 2026 — OpenSCAP rescan; if still failing after valid config, document as scanner false positive	**Low**	**Medium**	System Administrator	Known intermittent issue with SSG checks validating sudoers drop-in files in /etc/sudoers.d/ vs. monolithic /etc/sudoers. Manual verification is required before accepting.
POAM-012	**RHEL-09-252020**	CCE-87077-4	Chrony — Use Server Directive (Not Pool)	II	Medium	Planned — Requires Organizational NTP Infrastructure	Q2 2026	Q2 2026 — Obtain approved DoD NTP server addresses from ISSO/network team Q2 2026 — Replace pool directives in /etc/chrony.conf with explicit server directives Q2 2026 — Verify time sync: chronyc tracking && chronyc sources; OpenSCAP rescan	**Low**	**Medium**	System Administrator / Network Team	DoD reference NTP servers: tick.usno.navy.mil, tock.usno.navy.mil. Configuration change is low-risk but requires organizational NTP address approval.
POAM-013	**RHEL-09-631015**	CCE-89737-1	Enable Certmap in SSSD for PKI/CAC Authentication	II	Medium	Planned — Requires PKI/CAC Infrastructure	Pre-production deployment	Pre-Prod — Install sssd and sssd-tools; obtain DoD CA certificate chain from PKI team Pre-Prod — Configure [certmap/<domain>/<rule>] in sssd.conf with matchrule and maprule Pre-Prod — Integrate with AD/LDAP identity provider; test CAC authentication; OpenSCAP rescan	**Low**	**Medium**	Identity Management / ISSO	Lab environment lacks DoD CAC cards and PKI infrastructure. No meaningful residual risk in isolated lab. Must be completed before any system accreditation.
POAM-014	**RHEL-09-231010**	CCE-83468-9	/home on Separate Partition	III	Low	Planned — Pre-Provisioning Architectural Item	Next provisioning cycle	Next Build — Define /home as dedicated LVM LV in kickstart configuration (minimum 10GB or 10% of available storage) Next Build — Set appropriate mount options in /etc/fstab Next Build — OpenSCAP rescan to confirm partition compliance	**Low**	**Low**	System Administrator	Installation-time decision cannot be automated post-install without downtime. Build template should be updated to include this partition.
POAM-015	**RHEL-09-231015**	CCE-90845-9	/tmp on Separate Partition	III	Low	Planned — tmpfs Alternative Available	Q2 2026	Q2 2026 — Enable systemd tmp.mount unit: systemctl enable --now tmp.mount Q2 2026 — Verify: findmnt /tmp confirms tmpfs with nodev,nosuid,noexec	**Low**	**Low**	System Administrator	Quick win — tmpfs mount resolves this without repartitioning. systemd-provided

POA&M ID	STIG ID	CCE	Finding Title	CAT	Severity	Current Status	Target Date	Milestones	Lab Risk	Prod Risk	POC	Notes / Comments
								Q2 2026 — OpenSCAP rescan to confirm compliance				tmp.mount unit is available on all RHEL 9 installs.
POAM-016	**RHEL-09-231020**	CCE-83466-3	/var on Separate Partition	III	Low	Planned — Pre-Provisioning Architectural Item	Next provisioning cycle	Next Build — Define /var as dedicated LVM LV in kickstart (minimum 20GB for log-heavy systems) Next Build — Set appropriate mount options; configure logrotate for /var/log Next Build — OpenSCAP rescan to confirm partition compliance	**Low**	**Low**	System Administrator	Installation-time decision. Build template should be updated. /var is the parent of /var/log and /var/log/audit — all three should be isolated together.
POAM-017	**RHEL-09-231025**	CCE-90848-3	/var/log on Separate Partition	III	Low	Planned — Pre-Provisioning Architectural Item (Elevated Priority)	Next provisioning cycle — Elevated priority	Next Build — Define /var/log as dedicated LVM LV in kickstart (minimum 15GB; size based on audit retention policy) Next Build — Configure rsyslog/journald retention limits and log rotation policy Next Build — OpenSCAP rescan; verify logrotate operational post-build	**Low**	**Medium**	System Administrator	Elevated priority vs. /home and /var. Log availability is critical in DoD environments. Failure to protect /var/log risks audit trail loss.
POAM-018	**RHEL-09-231030**	CCE-90847-5	/var/log/audit on Separate Partition	III	Low	Planned — Pre-Provisioning Architectural Item (Highest Priority in CAT III)	Next provisioning cycle — Highest priority in CAT III group	Next Build — Define /var/log/audit as dedicated LVM LV (DoD minimum: 10GB; recommend: 30-day audit volume calculation) Next Build — Configure /etc/audit/auditd.conf: space_left_action=email, admin_space_left_action=halt, max_log_file_action=rotate Next Build — Verify auditd retention policy; OpenSCAP rescan; test auditd behavior on disk boundary	**Low**	**High**	System Administrator / ISSO	Most critical CAT III finding. Audit trail integrity is a non-negotiable DoD accreditation requirement. auditd halt-on-failure means an unprotected /var/log/audit is simultaneously an availability risk.

Remediation Roadmap

Phase 1 — Q2 2026: Quick Wins and Organizational Configuration

Estimated effort: 12–16 hours. These items require no system rebuild, only configuration changes and organizational input.

POA&M ID	STIG ID	Finding	Action Required	Effort	Dependency
POAM-004	RHEL-09-212045	grub2 Bootloader Password	Obtain credential policy approval; configure /etc/grub.d/01_users; rebuild grub.cfg; escrow in vault	~1 hr + approval	ISSO credential policy
POAM-005	RHEL-09-212040	grub2 Admin Username	Configure non-default superuser name alongside POAM-004	Included in POAM-004	Resolves with POAM-004
POAM-008	RHEL-09-231035	/var/tmp Partition	Enable systemd var-tmp.mount unit (tmpfs — no repartitioning required)	~15 min	None — quick win
POAM-009	RHEL-09-411095	Authorized Local Users	ISSO user inventory; lock/remove unauthorized accounts; inject approved list into OVAL variable	~2 hrs	ISSO user approval
POAM-011	RHEL-09-431016	SELinux Sudo Context	Verify configuration manually; update sudoers if needed; document false positive if not	~1 hr	Manual verification first
POAM-012	RHEL-09-252020	Chrony NTP Server Directive	Replace pool directives with approved DoD server directives in /etc/chrony.conf	~30 min	Org NTP server addresses
POAM-015	RHEL-09-231015	/tmp Partition	Enable systemd tmp.mount unit (tmpfs — no repartitioning required)	~15 min	None — quick win

Phase 2 — Q3 2026: FIPS Mode Activation (Resolves 5 Findings)

System rebuild required. One architectural decision (fips=1 at installation) resolves POAM-001, -002, -003, -006, and -007 simultaneously.

POA&M ID	STIG ID	Finding	Action Required	Effort	Notes
POAM-001	RHEL-09-671010	Enable FIPS Mode	Rebuild system with fips=1 in kickstart; verify with fips-mode-setup --check	~4 hrs (rebuild)	ROOT cause — resolves 5 items
POAM-002	RHEL-09-671010	Dracut FIPS Module	Auto-resolved by POAM-001: dnf install dracut-fips + dracut -f post-install	Included in POAM-001	Cascading
POAM-003	RHEL-09-671015	crypto.fips_enabled	Auto-resolved by POAM-001: kernel sets parameter at FIPS boot	Included in POAM-001	Cascading
POAM-006	RHEL-09-255070	SSH Client FIPS MACs	Auto-resolved by POAM-001: FIPS crypto policy activates for openssh.config	Included in POAM-001	Cascading
POAM-007	RHEL-09-255075	SSH Server FIPS MACs	Auto-resolved by POAM-001: FIPS crypto policy activates for opensshserver.config	Included in POAM-001	Cascading

Phase 3 — Next Provisioning Cycle: Disk Architecture & PKI Integration

These items cannot be remediated on a running system without downtime. They must be built into the next OS provisioning template and the pre-production deployment checklist.

POA&M ID	STIG ID	Finding	Action Required	Priority	Notes
POAM-018	RHEL-09-231030	/var/log/audit Partition	Kickstart: dedicated LVM LV; auditd.conf: admin_space_left_action=halt	**Critical**	Audit trail non-repudiation; also availability risk via auditd halt-on-failure
POAM-017	RHEL-09-231025	/var/log Partition	Kickstart: dedicated LVM LV; configure rsyslog/journald retention	**High**	Log availability critical for monitoring
POAM-013	RHEL-09-631015	SSSD Certmap (PKI/CAC)	Install sssd-tools; configure certmap rule; integrate with DoD PKI/AD	**High**	Required for DoD accreditation
POAM-016	RHEL-09-231020	/var Partition	Kickstart: dedicated LVM LV (min 20GB)	**Medium**	Parent of /var/log — coordinate all partitions
POAM-014	RHEL-09-231010	/home Partition	Kickstart: dedicated LVM LV (min 10GB)	**Normal**	Standard best practice
POAM-010	RHEL-09-213105	User Namespaces	Conduct container audit; apply sysctl if no containers; otherwise formal risk acceptance	**Decision Required**	AO must sign off if containers in use

Risk Acceptance Summary

The following table documents the formal risk acceptance posture for all 18 open POA&M items. Items marked 'Risk Acceptance Required' need explicit Authorizing Official signature.

POA&M	STIG ID	Finding	CAT	Lab Risk	Prod Risk	Target	Disposition	AO Sign-Off Required
POAM-001	RHEL-09-671010	Enable FIPS Mode	I	Moderate	High	Next provisioning cycle / Q3 2026	Accept — Deferred	Yes — Required
POAM-002	RHEL-09-671010	Enable Dracut FIPS Module	I	Moderate	High	Q3 2026 (simultaneous with POAM-001)	Accept — Deferred (Cascading)	Yes — Required
POAM-003	RHEL-09-671015	Set Kernel Parameter crypto.fips_enabled = 1	I	Moderate	High	Q3 2026 (simultaneous with POAM-001)	Accept — Deferred (Cascading)	Yes — Required
POAM-004	RHEL-09-212045	Set grub2 Bootloader Password	I	Low	High	Q2 2026	Planned	Yes — Required
POAM-005	RHEL-09-212040	Set grub2 Admin Username (Non-Default)	I	Low	High	Q2 2026 (simultaneous with POAM-004)	Planned	Yes — Required
POAM-006	RHEL-09-255070	SSH Client — Use FIPS 140-2 Validated MACs (openssh.config)	II	Low	Medium	Q3 2026 (with POAM-001)	Accept — Deferred (Cascading)	No
POAM-007	RHEL-09-255075	SSH Server — Use FIPS 140-2 Validated MACs (opensshserver.config)	II	Low	Medium	Q3 2026 (with POAM-001)	Accept — Deferred (Cascading)	No
POAM-008	RHEL-09-231035	/var/tmp on Separate Partition	II	Low	Medium	Q2 2026 — tmpfs alternative; or next build cycle	Planned	No
POAM-009	RHEL-09-411095	Only Authorized Local Users Permitted	II	Low	Medium	Q2 2026	Planned	No
POAM-010	RHEL-09-213105	Disable Unprivileged User Namespaces	II	Medium	Medium	Q2 2026 — Risk acceptance documentation	Risk Acceptance Required	Yes — Required
POAM-011	RHEL-09-431016	SELinux Context Elevation for Sudo	II	Low	Medium	Q2 2026 — Verification and remediation if needed	Under Investigation	No
POAM-012	RHEL-09-252020	Chrony — Use Server Directive (Not Pool)	II	Low	Medium	Q2 2026	Planned	No
POAM-013	RHEL-09-631015	Enable Certmap in SSSD for PKI/CAC Authentication	II	Low	Medium	Pre-production deployment	Planned — Pre-Production	No
POAM-014	RHEL-09-231010	/home on Separate Partition	III	Low	Low	Next provisioning cycle	Planned — Next Build	No

POA&M	STIG ID	Finding	CAT	Lab Risk	Prod Risk	Target	Disposition	AO Sign-Off Required
POAM-015	RHEL-09-231015	/tmp on Separate Partition	III	Low	Low	Q2 2026	Planned — Quick Win	No
POAM-016	RHEL-09-231020	/var on Separate Partition	III	Low	Low	Next provisioning cycle	Planned — Next Build	No
POAM-017	RHEL-09-231025	/var/log on Separate Partition	III	Low	Medium	Next provisioning cycle — Elevated priority	Planned — Next Build (Elevated)	No
POAM-018	RHEL-09-231030	/var/log/audit on Separate Partition	III	Low	High	Next provisioning cycle — Highest priority in CAT III group	Planned — Next Build (Highest CAT III Priority)	**Yes — Required**

Document Control & Sign-Off

Prepared By	System Owner / ISSO	Authorizing Official	Review Date
David Perez	_____	_____	22 April 2026
Version: 1.0 — Initial Release	Date: _____	Date: _____	Next Review: Q3 2026